

Personal Data Protection Handling Procedure

Doc ID: CMP-002	Version: 1.0	Effective: 2026-01-01	Access: INTERNAL
-----------------	--------------	-----------------------	------------------

This procedure establishes standard operating protocols for compliance with the Personal Data Protection Act 2010 (PDPA) across AEON Credit Service (M) Berhad. It details core data protection principles, procedures and operational timelines for handling Data Subject Access Requests within 21 calendar days, fees, secure data disposal, and mandatory incident response protocols for data breach notifications.

1.0 — Purpose and Scope

This document sets forth operational guidelines for AEON Credit Service (M) Berhad ('the Company') to ensure strict adherence to the Personal Data Protection Act 2010 (PDPA) and relevant Bank Negara Malaysia guidelines on customer data management. This procedure applies to all permanent, contract, and temporary employees, as well as appointed third-party service providers and data processors who handle customer personal data across retail financing, credit cards, hire purchase, and digital delivery channels.

2.0 — Core Personal Data Protection Principles

The Company mandates adherence to the seven key PDPA principles across all customer touchpoints: (1) General Principle: personal data must only be processed with explicit, informed consent for lawful purposes; (2) Notice and Choice Principle: data subjects must be informed via written Privacy Notices of data collection purposes and rights; (3) Disclosure Principle: personal data must not be disclosed to unapproved third parties without explicit consent; (4) Security Principle: robust technological, administrative, and physical safeguards must protect against loss, misuse, or unauthorized modification; (5) Retention Principle: data must not be kept longer than necessary for the fulfillment of financing agreements or legal requirements; (6) Data Integrity Principle: all reasonable steps must ensure customer data is accurate, complete, and updated; and (7) Access Principle: customers retain the statutory right to request access to and correction of their personal records.

3.0 — Data Subject Access and Correction Procedures

All Data Subject Access Requests (DSAR) and Data Correction Requests must be formally submitted through registered branch counters, designated customer service portals, or via verified written correspondence using Form PDPA-REQ-01. Customer service personnel must verify the applicant's identity using primary identification (MyKad or passport) prior to registering the request in the central compliance tracking system. Requests regarding credit facility assessments, repayment histories, or account statements must be validated against core customer databases without altering historical transaction trails.

4.0 — Fulfillment Timelines and Statutory Extension Rules

In strict compliance with statutory regulations, all verified Data Subject Access Requests must be fulfilled within twenty-one (21) calendar days from the official date of receipt and verification. If fulfillment cannot be completed within the initial 21-day window due to multi-system data aggregation, archival retrieval, or system unavailability, an extension not exceeding an additional fourteen (14) calendar days may be invoked. In such instances, a formal Notification of Extension (Form PDPA-EXT-01) stating substantive reasons must be issued to the data subject prior to the expiration of the original 21-day timeline.

5.0 — Personal Data Breach Identification and Escalation

Any incident involving actual, suspected, or potential unauthorized acquisition, disclosure, alteration, or loss of personal data constitutes a Personal Data Breach. Any staff member identifying an anomaly must report the incident to the Data Protection Officer (DPO) and IT Information Security within two (2) hours of discovery. The Incident Response Team must contain the exposure, conduct an impact triage within twenty-four (24) hours, and determine regulatory reporting obligations to the Personal Data Protection Commissioner (PDP) and relevant financial authorities.

6.0 — Data Retention, Storage, and Secure Disposal

Personal data, financing documents, credit underwriting evaluations, and signed agreements must be securely retained for a minimum of seven (7) years following the closure, settlement, or termination of the relevant credit facility, in accordance with statutory accounting and anti-money laundering legislation. Upon the expiration of the mandatory retention period, electronic records must be sanitized using cryptographic wiping standards, and physical paper files must be destroyed via cross-cut shredding under the physical supervision of an authorized compliance officer.

7.0 — Third-Party Data Processors and Cross-Border Transfers

Outsourced service providers, recovery agents, telemarketing partners, and cloud computing vendors processing data on behalf of the Company must enter into legally binding Data Processing Agreements (DPA). These contracts enforce confidentiality, data minimization, and audit verification. Cross-border transfers of personal data are strictly prohibited unless the destination jurisdiction provides an equivalent standard of protection and explicit consent has been recorded from the data subject in line with Section 129 of the PDPA.

8.0 — Compliance Audits, Logging, and Disciplinary Sanctions

All queries, modifications, disclosures, and access logs concerning customer personal data must be immutably recorded in audit trails and retained for review by Internal Audit. Deliberate non-compliance, unauthorized data scraping, sale of customer records, or negligence in breach escalation will trigger immediate disciplinary action up to summary dismissal, alongside potential criminal referral under Malaysian data protection laws.

Schedule / Reference Table

Request / Incident Category	Scope of Data Requested or Handled	Prescribed Processing Fee	Statutory SLA Timeline	Escalation and Approving Authority
Standard Data Access Request	Basic customer profile, contact details, account demographics, and current facility statuses	RM 10.00	Within 21 calendar days	Branch Operations Manager / Customer Service Lead
Comprehensive Data Access Request	Full credit file including historical underwriting logs, score ranges, and payment histories	RM 100.00	Within 21 calendar days (extendable by 14 days)	Head of Customer Care and Data Protection Officer
Data Correction Request	Rectification of outdated contact information, marital status, or employer details	RM 0.00 (No fee)	Within 14 calendar days	Operations Processing Unit Supervisor
Consent Revocation (Direct Marketing)	Withdrawal of consent for third-party cross-selling and promotional communications	RM 0.00 (No fee)	Within 7 business days	Digital Marketing and CRM Campaign Operations
High-Severity Data Breach Incident	Unauthorized leak, exfiltration, or loss affecting 100 or more customer records	Not Applicable	Immediate containment; regulatory alert within 72 hours	Chief Risk Officer, Head of Legal & DPO, Executive Committee